

EMAIL SECURITY ANALYSIS & PHISHING INVESTIGATION

SOC Detection & Investigation Lab

Prepared By:
Samadhan Lahu Nikam

B.Sc. Cyber & Digital Science

Field	Details
Case Type	Suspicious Email / Potential Phishing
Environment	Controlled Cybersecurity Lab
SIEM	Splunk Enterprise
Email Collection	Gmail IMAP
Header Analysis	MXToolbox
URL Reputation	VirusTotal
Severity	High — Suspicious / Potential Phishing
Report Version	1.0
Date	September 2026

Executive Finding

A controlled suspicious email was collected through the Gmail IMAP monitoring pipeline and analyzed using email-header authentication results, URL/domain extraction, external URL reputation intelligence, and Splunk-based detection and visualization.

The analyzed message contained a password reset themed subject and an externally hosted URL. SPF and DKIM authentication were observed as passing; however, authentication success alone does not establish that the message or its destination is safe. VirusTotal returned detections from 2 of 90 security vendors, providing an additional suspicious reputation signal.

Overall assessment: High — Suspicious / Potential Phishing, pending further investigation.

Evidence Handling Note

This document describes a controlled security-testing scenario. Personal email addresses, public IP addresses, message identifiers and other unnecessary identifiers should be redacted before external publication.

September 2026

1. Email Evidence

Purpose: establish the initial observable characteristics of the message before enrichment or SIEM analysis.

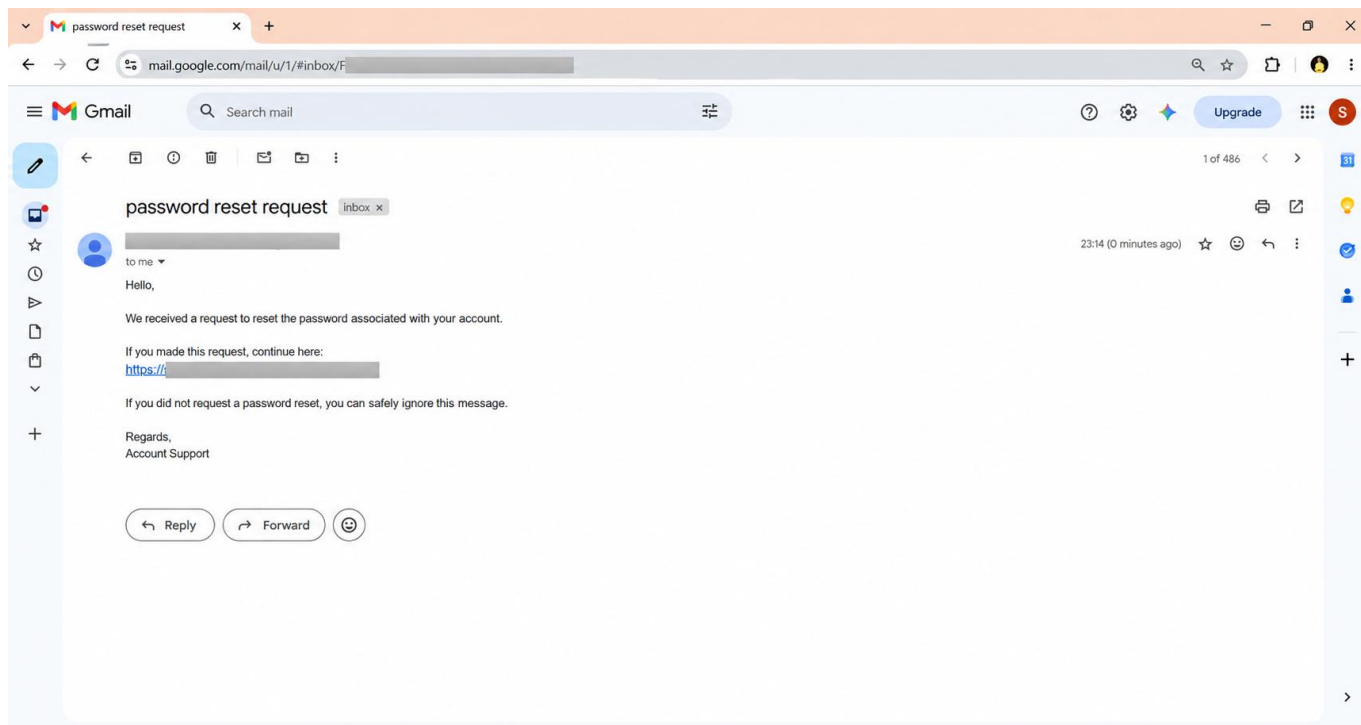


Figure 1 — Controlled test email / suspicious password-reset themed message

Observed Indicators

Password-reset/security-themed social-engineering context.

External URL included in the message.

Message was used as controlled test data for the defensive analysis pipeline.

The message alone is not sufficient to establish compromise; URL, header and environmental evidence must be correlated.

Analyst Assessment

The combination of a credential-related theme and an external link is a reasonable trigger for additional analysis. This is an indicator of suspicion, not standalone proof of phishing.

2. Email Header & Authentication Evidence

Purpose: examine sender infrastructure and message authentication signals using header-analysis tooling.

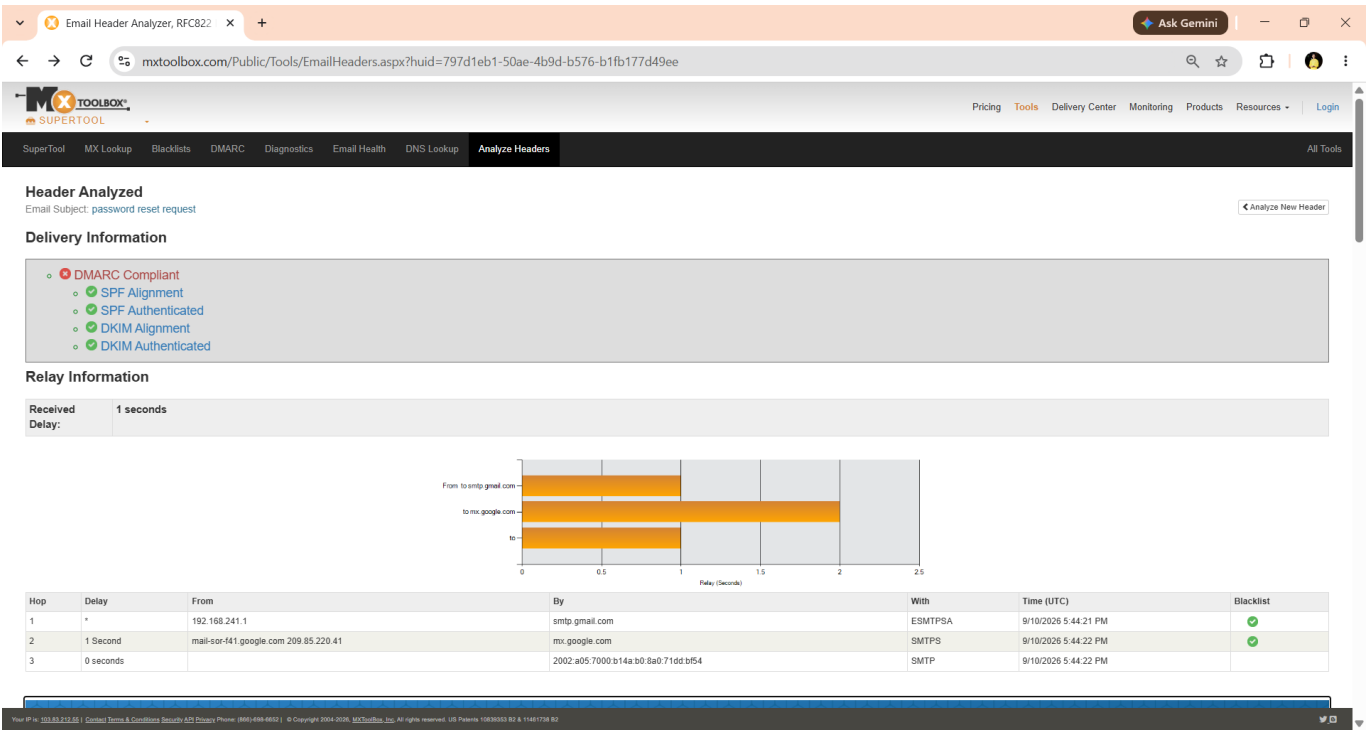


Figure 2 — MXToolbox header/authentication analysis

Key Observations

SPF authentication was observed as PASS.

DKIM authentication was observed as PASS.

Authentication results must be interpreted in the context of the visible From domain and alignment.

Passing authentication does not establish that the message content or destination URL is benign.

L2/L3 Relevance

An analyst should preserve the complete Authentication-Results, Return-Path, From, DKIM and Received header chain for correlation with mail-server and identity telemetry.

3. SPF / DKIM / DMARC Interpretation

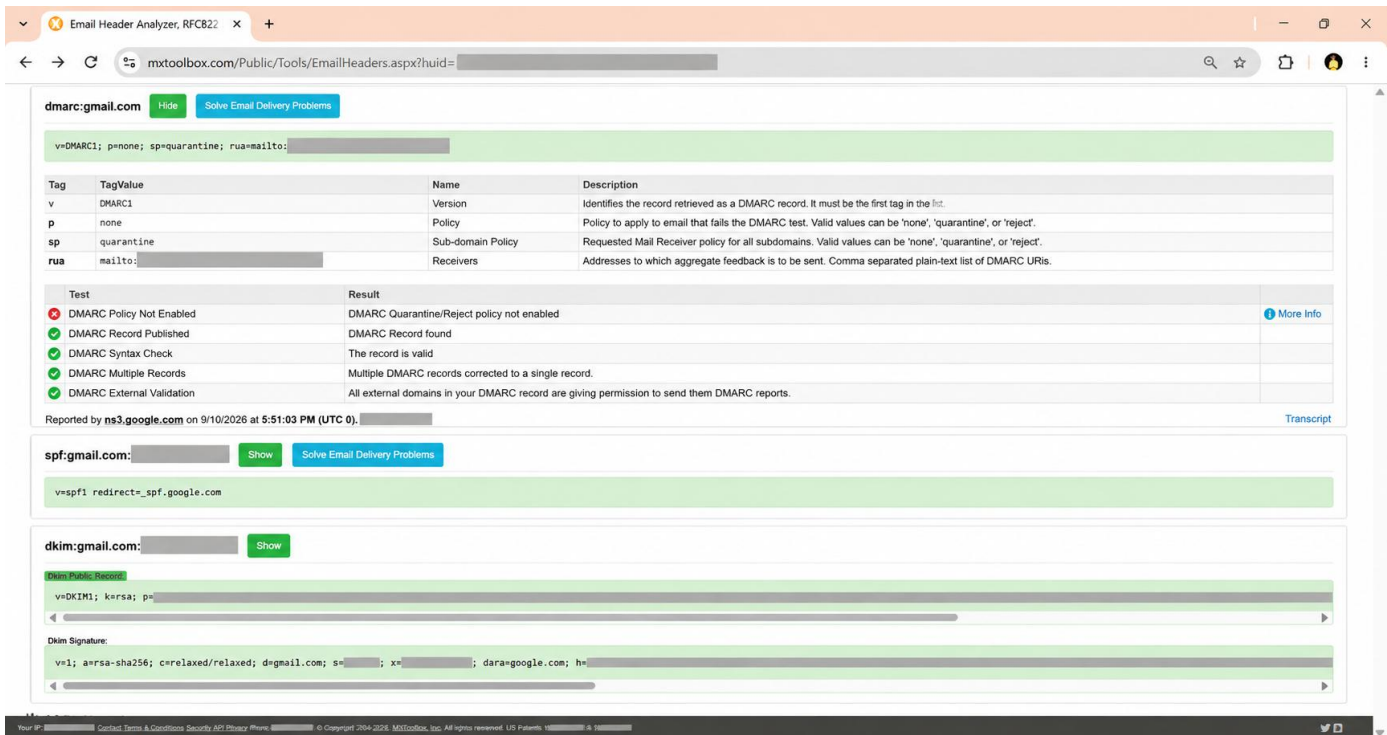


Figure 3 — Authentication details

Interpretation

Control	Observed Result	Meaning
SPF	PASS	Sending infrastructure was authorized by the SPF evaluation.
DKIM	PASS	The message carried a valid DKIM signature for the evaluated domain/key.
DMARC	Policy context observed	DMARC evaluates SPF/DKIM alignment and applies the domain policy; authentication success is not a benignity verdict.

Important: a malicious actor using a legitimate or compromised sending service can still produce messages that pass SPF and DKIM. Email authentication should therefore be correlated with content, URL reputation, domain intelligence, recipient behavior and endpoint telemetry.

4. URL Reputation Analysis

Purpose: independently evaluate the external URL observed in the email.

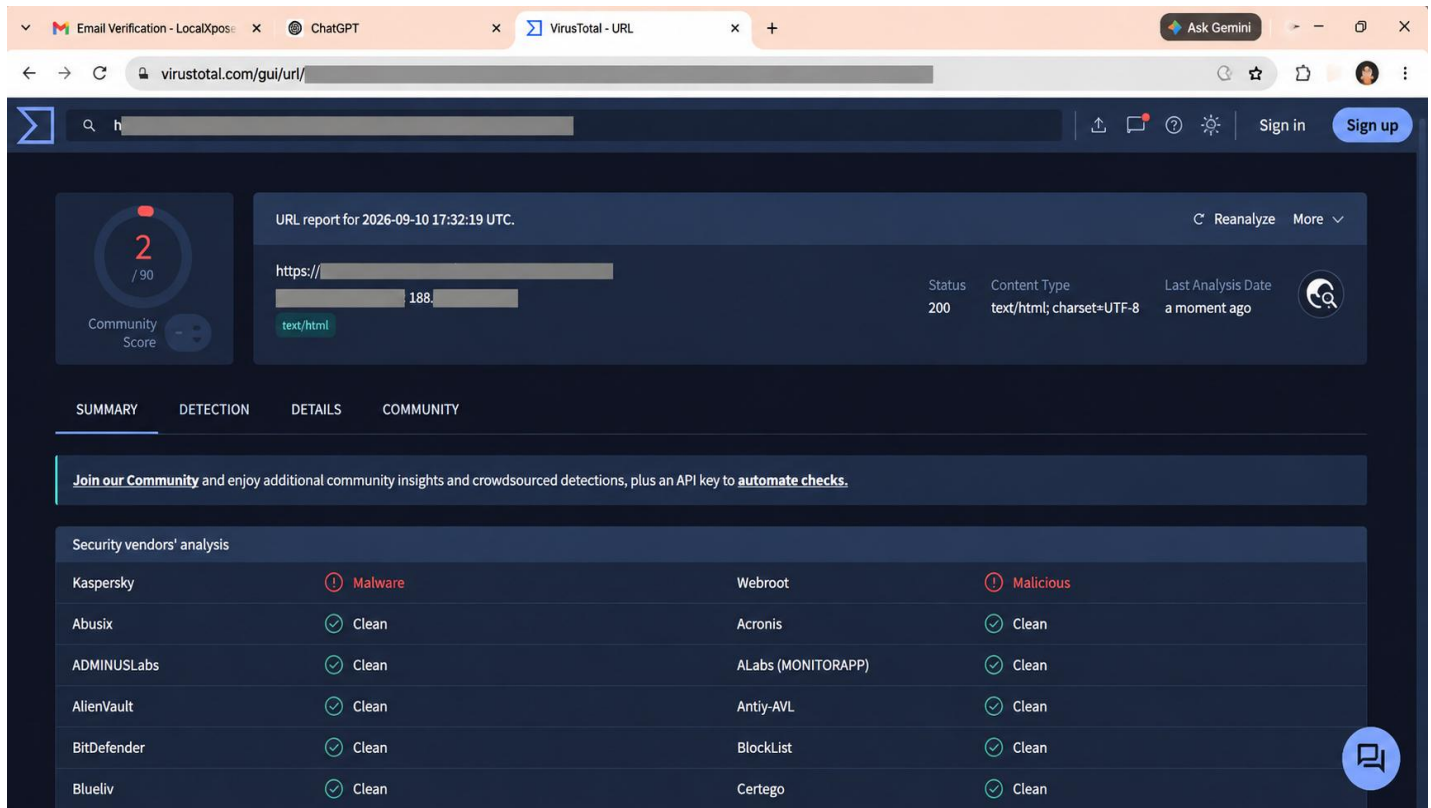


Figure 5 — VirusTotal URL reputation analysis

Observed Result

VirusTotal showed detections from 2 of 90 security vendors, including detections labelled Malware/Malicious by vendors visible in the evidence.

Analyst Interpretation

The result is a meaningful suspicious-reputation signal, but 2/90 detections should not be treated as definitive proof by itself. L2/L3 should correlate the URL with DNS history, domain age/reputation, redirect behavior, proxy/DNS logs and endpoint activity.

Recommended IOC Handling

Record the complete URL and normalized domain in the case record, with sensitive lab identifiers redacted in public copies.

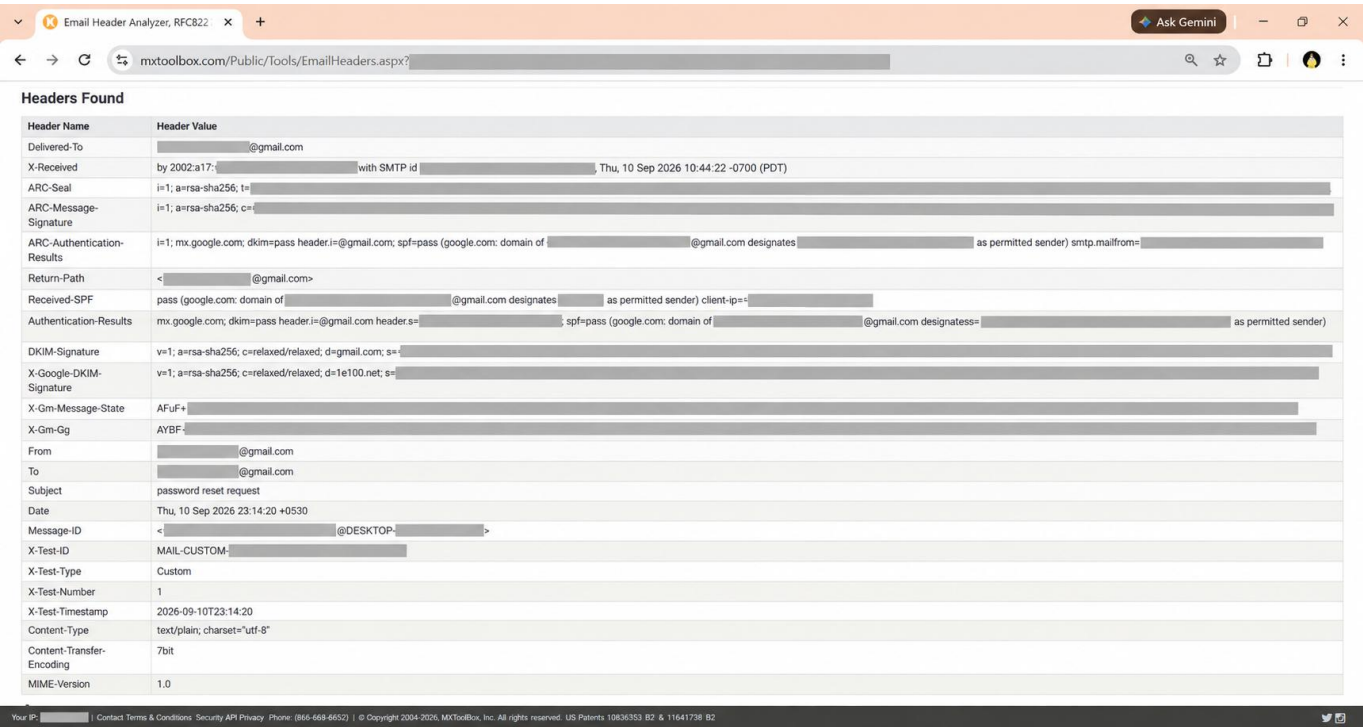
Search historical email and proxy/DNS telemetry for the domain and URL.

Check for URL redirects and destination changes.

If independently confirmed malicious, consider blocking at appropriate security controls.

5. Raw Header Evidence

Purpose: retain low-level evidence supporting authentication and message-routing analysis.



The screenshot shows a web browser window with the URL `mxtoolbox.com/Public/Tools/EmailHeaders.aspx?`. The page title is "Email Header Analyzer, RFC822". The main content area is titled "Headers Found" and displays a table of email headers. The headers are listed in two columns: "Header Name" and "Header Value". The headers include: "Delivered-To", "X-Received", "ARC-Seal", "ARC-Message-Signature", "ARC-Authentication-Results", "Return-Path", "Received-SPF", "Authentication-Results", "DKIM-Signature", "X-Google-DKIM-Signature", "X-Gm-Message-State", "X-Gm-Gg", "From", "To", "Subject", "Date", "Message-ID", "X-Test-ID", "X-Test-Type", "X-Test-Number", "X-Test-Timestamp", "Content-Type", "Content-Transfer-Encoding", and "MIME-Version". The values are mostly redacted with grey bars, but some are visible, such as the "Subject" being "password reset request" and the "Date" being "Thu, 10 Sep 2026 23:14:20 +0530".

Header Name	Header Value
Delivered-To	@gmail.com
X-Received	by 2002.a17: with SMTP id Thu, 10 Sep 2026 10:44:22 -0700 (PDT)
ARC-Seal	i=1; a=rsa-sha256; t=
ARC-Message-Signature	i=1; a=rsa-sha256; c=
ARC-Authentication-Results	i=1; mx.google.com; dkim=pass header.i=@gmail.com; spf=pass (google.com: domain of @gmail.com designates as permitted sender) smtp.mailfrom=
Return-Path	<@gmail.com>
Received-SPF	pass (google.com: domain of @gmail.com designates as permitted sender) client-ip=
Authentication-Results	mx.google.com; dkim=pass header.i=@gmail.com header.s=; spf=pass (google.com: domain of @gmail.com designates as permitted sender)
DKIM-Signature	v=1; a=rsa-sha256; c=relaxed/relaxed; d=gmail.com; s=
X-Google-DKIM-Signature	v=1; a=rsa-sha256; c=relaxed/relaxed; d=1e100.net; s=
X-Gm-Message-State	AFuF+
X-Gm-Gg	AYBF+
From	@gmail.com
To	@gmail.com
Subject	password reset request
Date	Thu, 10 Sep 2026 23:14:20 +0530
Message-ID	<@DESKTOP- >
X-Test-ID	MAIL-CUSTOM-
X-Test-Type	Custom
X-Test-Number	1
X-Test-Timestamp	2026-09-10T23:14:20
Content-Type	text/plain; charset="utf-8"
Content-Transfer-Encoding	7bit
MIME-Version	1.0

Figure 6 — Raw email header evidence

Fields of Interest for Investigation

Authentication-Results

Received-SPF

DKIM-Signature

Return-Path

From / To / Cc / Bcc

Received chain and timestamps

Message-ID and mail infrastructure identifiers

Evidence Hygiene

For a public portfolio version, redact email addresses, Message-IDs, public IP addresses, unique hostnames and any other identifiers that are not necessary to demonstrate the security analysis.

7. Email Parsing, Indicators & Detection Logic

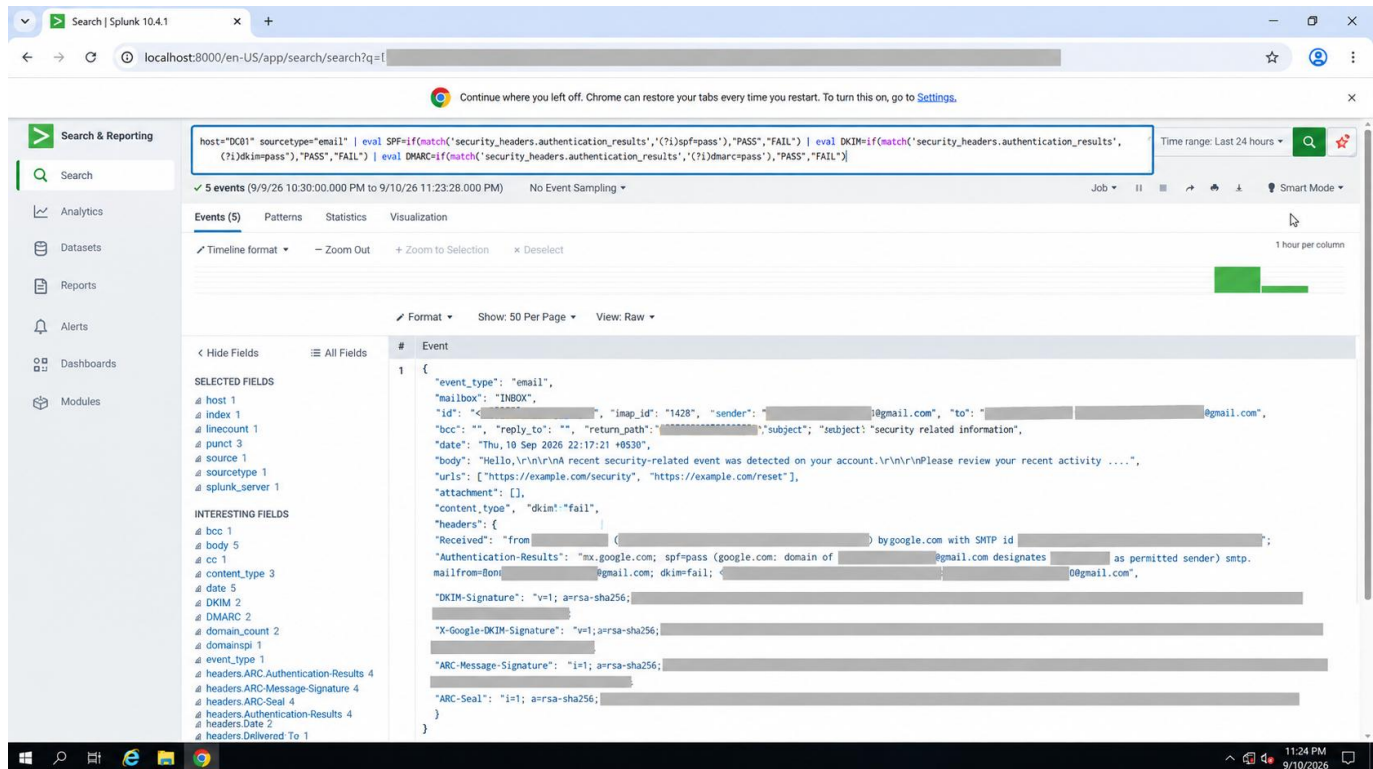


Figure 8 — Email parsing / analysis evidence

Extracted Security Signals

Sender and recipient metadata

Subject and timestamp

Mailbox/source context

URLs and domains

SPF, DKIM and DMARC-related authentication results

Suspicion indicators/reasons

Current Detection Approach

The current implementation is best described as rule-based suspicious-email identification. A message can be surfaced when observable indicators such as a suspicious security/credential-themed subject and an embedded URL are present.

This should not be described as an enterprise-grade or machine-learning phishing classifier. The current dataset and rule set are suitable for a controlled lab demonstration and can be expanded with additional benign and malicious samples, scoring and enrichment.

8. Splunk SIEM Evidence & Dashboard

Purpose: demonstrate centralized visibility and analyst-oriented investigation.

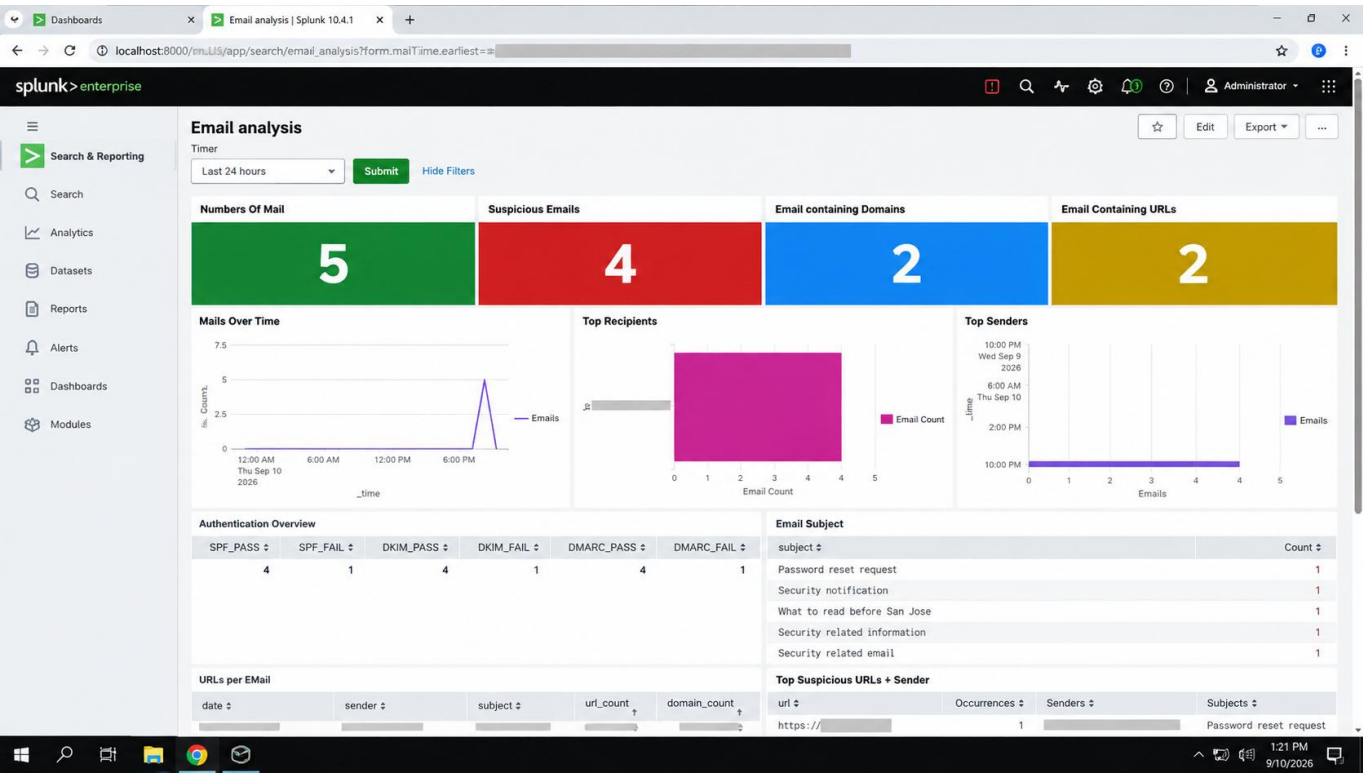


Figure 9 — Splunk email-security dashboard

Dashboard Coverage

Total email count

Suspicious email count

Emails containing domains

Emails containing URLs

Email volume over time

Top senders and recipients

Authentication overview

URL and domain visibility

Suspicious email results

The Splunk layer is the strongest operational component of the project because it converts collected email data into searchable and visual security telemetry. The dashboard supports triage, correlation and investigation rather than merely displaying raw messages.

9. Suspicious Email Investigation & IOC Summary

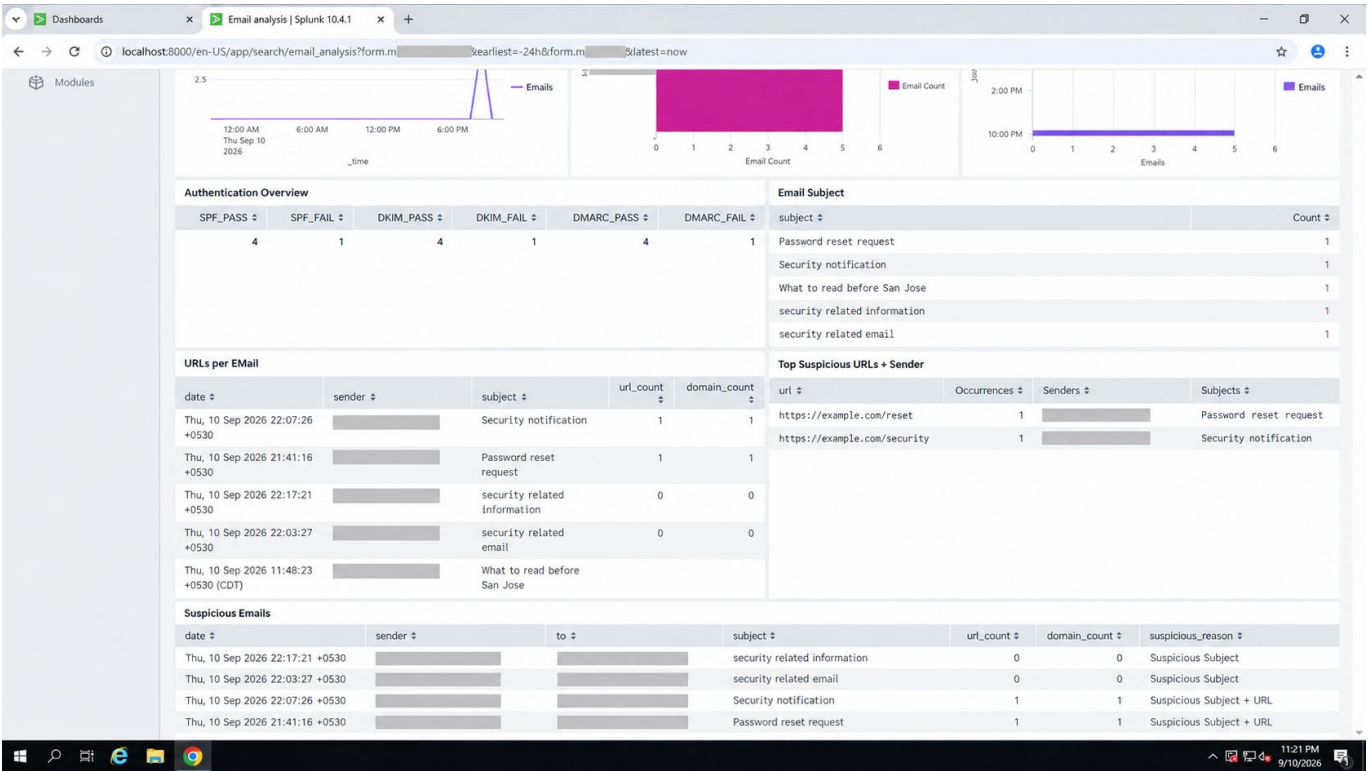


Figure 10 — Suspicious email / investigation results

Investigation Summary

Evidence	Observation	Assessment
Email theme	Password-reset/security context	Suspicious social-engineering indicator
URL	External URL present	Requires reputation and destination analysis
SPF	PASS	Authentication signal; not a benignity verdict
DKIM	PASS	Authentication signal; not a benignity verdict
VirusTotal	2/90 vendor detections	Suspicious reputation signal
Splunk	Message surfaced in suspicious-email view	Supports centralized SOC triage

IOC Summary

IOC Type	Value	Handling
URL	[REDACTED IN PUBLIC REPORT]	Investigate / enrich
Domain	[REDACTED IN PUBLIC REPORT]	Search historical telemetry
Sender	[REDACTED]	Correlate with mail history
Subject	Password reset request	Search for campaign recurrence
IP	[REDACTED]	Correlate with network/DNS evidence

Severity

HIGH — Suspicious / Potential Phishing. The classification is based on the combination of credential-themed content, an external URL, URL reputation detections and the ability to surface the message through the SIEM workflow. Confirmation of compromise requires additional telemetry.

10. L2/L3 Handoff, Recommendations & Conclusion

L2 Investigation Checklist

Determine whether any recipient clicked or submitted credentials to the URL.

Search for additional recipients who received the same or similar message.

Search Splunk for the sender, subject, domain and URL across the available time range.

Review DNS/proxy/endpoint telemetry for connections to the destination.

Check whether the domain or URL appears in other security alerts.

Inspect any attachments and calculate hashes where applicable.

L3 Investigation / Enrichment

Perform historical DNS and domain-reputation analysis.

Analyze redirect chains and final destinations.

Correlate with identity/authentication logs for suspicious sign-ins.

Correlate with endpoint/browser telemetry for post-click activity.

Identify related infrastructure and campaign-wide indicators.

Tune detection logic based on false positives and confirmed incidents.

Containment / Response Guidance

Quarantine the message when maliciousness is independently confirmed.

Block confirmed malicious URLs/domains through appropriate security controls.

If credential submission or compromise is suspected, investigate and remediate the affected identity.

Preserve original email and header evidence for incident-response records.

Limitations

The current implementation is a controlled lab and not a production email-security platform.

The test dataset is limited and should be expanded before making quantitative claims about detection accuracy.

External reputation services can produce false positives/negatives and should be correlated with other evidence.

SPF/DKIM/DMARC results establish authentication/alignment signals, not message intent or safety.

Conclusion

The project demonstrates an end-to-end defensive email-security workflow: controlled email generation/collection, IMAP-based acquisition, parsing and IOC extraction, authentication analysis, external URL reputation checking, structured telemetry and Splunk-based SOC visualization. The current implementation is a solid lab foundation for further detection engineering, enrichment, correlation and automated response.

Recommended next iteration: introduce risk scoring, attachment/hash analysis, domain/DNS enrichment, historical campaign correlation, richer Splunk detections and a larger labeled test dataset.